

CCSP D2 資料安全

CCSP flashcards for Knowt. 55 cards. Upload this PDF to AI PDF Summarizer.

Q001 Cloud Secure Data Lifecycle 六個階段依序是什麼？

A Create → Store → Use → Share → Archive → Destroy。口訣 C-S-U-S-A-D。

Q002 資料一建立時，最早應執行哪項治理活動？

A Classification。後續 encryption、IAM、DLP、retention、sharing、destruction 都可能依賴它。

Q003 Share 之前是哪一個 lifecycle phase？

A Use。Encrypt / Protect / Validate 是 control，不是 phase。

Q004 Control 和 lifecycle phase 差在哪？

A Phase 是資料所處階段；control 是保護手段。看到 encrypt / tokenize / DLP 先問是不是被拿來冒充 phase。

Q005 Metadata 是什麼？

A Data about data：建立時間、作者、檔案類型、位置、擁有者、schema 等描述資訊。

Q006 Label / Tag 是什麼？

A 刻意附加的分類或治理標誌，例如 Confidential、PII、Restricted。

Q007 Classification 問的是什麼問題？

A 這份資料有多敏感 / 屬哪一類？它是決策，不是自動產生的描述欄位。

Q008 Data Discovery 的核心功能是什麼？

A 找出敏感資料在哪裡、內容是什麼，並做內容檢視與盤點。

Q009 DLP 的核心功能是什麼？

A 依內容辨識敏感資料，監控或阻止不當流動。記：DLP = movement。

Q010 IRM / DRM 與 DLP 最大差異是什麼？

A IRM 控制授權後能做什麼 (view / copy / print / forward)；DLP 關心資料正在去哪裡。

Q011 DRM 與 Enterprise DRM / IRM 的關係？

A DRM 是防止未授權複製的廣義機制；Enterprise DRM / IRM 是其企業文件權限子集。

Q012 DLP 一定要裝在 client 上嗎？

A 不一定。可位於 endpoint、network 或 cloud / SaaS / CASB。不要背「egress monitoring 一定有 client agent」。

Q013 Content-based discovery 較接近哪類控制？

A Egress monitoring / DLP 類方案，不是 DRM。DRM 管使用權，不管內容發現。

Q014 DLP 能不能當合約仲裁或 HR 評估工具？

A 不能。DLP 是 data-centric control：識別、分類比對、監控、告警 / 阻擋。

Q015 VM 看到邏輯磁碟但實體不一定靠近 compute node，通常是哪種儲存？

A Volume / Block storage。不要選 CDN。

Q016 Object storage 的特徵是什麼？

A Object + metadata + identifier，通常經 API 存取。

Q017 CDN 的核心目的是什麼？

A 把內容快取 / 派發到靠近使用者處，追求 delivery / performance，不是通用附加儲存區。

Q018 IaaS / PaaS / SaaS 典型儲存對應？

A IaaS → Volume / Object；PaaS → Databases；SaaS 常搭配 CDN 派發靜態內容。

Q019 為什麼 traditional overwrite 在 cloud 可能不可靠？

A 客戶通常無法控制實體媒體，且資料可能在 snapshot、replica、backup 中。不是因為「主管機關不喜歡覆寫」。

Q020 Physical destruction 和 crypto-erasure 哪個一定比較安全？

A 不能脫離情境。先問誰控制實體媒體。

Q021 雲端最普遍可行的資料銷毀方法通常是什麼？

A Encryption / crypto-erasure（銷毀金鑰使資料不可讀）。Degaussing、物理銷毀、覆寫對客戶常不可行。

Q022 Degaussing 為什麼很少是雲端客戶的答案？

A 客戶通常無法保證對 CSP 磁性媒體執行消磁。

Q023 PCI DSS 交易授權後通常不能保留的 SAD 是什麼？

A CVV / CVC。PAN 可在符合保護要求下儲存；PCI DSS 本身是產業標準不是法律。

Q024 TDE 的加密引擎在哪一層？

A Database / DBMS 層。不要把 KMS 當成 encryption engine。

Q025 KMS 做什麼？

A 管理金鑰生命週期、輪換與存取控制；管 key，不一定執行資料加密。

Q026 HSM 是什麼？

A 防篡改硬體，用於金鑰儲存與密碼運算。它是安全容器，不是金鑰本身。

Q027 BYOK 與 HYOK 差在哪？

A BYOK：客戶自帶 key 給 CSP 使用；HYOK：客戶自己持有 key，CSP 不持有。

Q028 Envelope encryption 是什麼？

A Data key 加密資料，master key 再加密 data key。

Q029 Tokenization 是什麼？

A 用 token 替代真值，原值存在 token vault。

Q030 Dynamic masking 與 static masking 差在哪？

A Dynamic：查詢 / 顯示時依角色遮罩、不改原資料；Static：產生已遮罩副本。

Q031 Format-Preserving Encryption 的特點？

A 加密後仍保持原資料格式，例如看起來仍像信用卡號。

Q032 分類是否永久不變？

A 不是。時間、用途改變、所有權移轉、法規狀態都可能觸發 reclassification。

Q033 哪一項通常不是 reclassification 的理由？

A Color change。顏色改變通常與敏感度分類無關。

Q034 Data Controller 與 Processor 差在哪？

A Controller 決定 why + how；Processor 依指示處理。CSP 常可能是 processor / subprocessor。

Q035 PII 放在 CSP，CSP 發生 breach，customer 的 accountability 消失嗎？

A 不會。責任可共享或委外，歸責通常仍在 data owner / controller。

Q036 CSA CCM 是什麼？

A 雲端控制框架 (control objectives / domains)，可 mapping 其他標準。不要背完整 mapping 清單。

Q037 CAIQ 是什麼？

A CSA 的評估問卷，用來詢問 CCM 控制如何實作。

Q038 STAR 是什麼？

A CSA 的雲端供應商保證 / 登錄計畫，不是成熟度模型。

Q039 SSAE 18 與 SOC 1 / SOC 2 差在哪？

A SSAE 18 是認證 / attestation 標準；SOC 1 / 2 是報告類型。

Q040 SOC 1 與 SOC 2 各看什麼？

A SOC 1：財務報導控制；SOC 2：security / privacy 等信任原則控制。

Q041 Anonymization 的考試重點？

A 降低或移除身份關聯，使資料無法合理識別個人；不要和 masking / tokenization 混成同一個答案。

Q042 Egress monitoring 與 stateful inspection 差在哪？

A Stateful inspection 是防火牆 / 網路狀態追蹤；egress monitoring / DLP 是看敏感資料是否外流。

Q043 Create 階段之後，Store 通常要做什麼？

A 依 classification 選擇適當儲存與加密。

Q044 Archive 階段的核心是什麼？

A Retention 與長期保護，不是立即 destroy。

Q045 雲端資料刪除還要考慮哪些複本？

A Replicas、snapshots、backups。銷毀「邏輯物件」不等於所有複本都消失。

Q046 Key rotation 的目的？

A 定期更換金鑰，降低長期暴露與金鑰洩漏衝擊。

Q047 Key escrow 是什麼？

A 以受控方式把金鑰託管給第三方或指定保管者，以便緊急復原，但會引入託管風險。

Q048 資料分類為何要盡早？

A 愈早分類，後續儲存位置、加密強度、DLP 政策、分享限制與銷毀方法才有依據。

Q049 IRM 即使檔案已被合法取得，仍可限制什麼？

A View、copy、print、forward、expiration 等使用權限。

Q050 Discovery 能做 classification 嗎？

A Discovery 可依內容協助識別與分類，但 classification 仍是敏感度決策；兩者不要劃等號。

Q051 D2 最常見的混用錯誤是什麼？

A 把 Metadata、Label、Classification、Discovery、DLP、IRM 當成同一個「資料保護」答案。

Q052 題目出現「自動附加到資料、描述資料本身」最接近什麼？

A Metadata，不是 label。Label 是刻意打上的分類標記。

Q053 雲端無法保證物理銷毀時，可行替代是什麼？

A 在金鑰架構正確的前提下做 cryptographic erasure / crypto-shredding。

Q054 FIPS 140-2 與 FIPS 140-3 怎麼記？

A FIPS 140-2 是 legacy；FIPS 140-3 是現行世代。理解歷史即可，不要用舊版建立新模型。

Q055 資料安全題先問哪五件事？

A 誰擁有資料、誰定政策、誰接受風險、誰操作控制、誰仍須負責 (accountable)。